

第9章 信息安全核心知识点

一、真题考情概览

2024年以来，信息安全在三个科目中均有分布：综合知识常考加密算法、认证技术、访问控制；案例分析出现了**密码学专题案例**（信息安全三大目标、3DES、抗抵赖、重放攻击、被动攻击判断），以及**RBAC与渗透测试、数据容灾案例**；2026年上半年综合知识还考了“大批量数据对称加密选AES”。整体上教材（第9章）的保密性—认证—访问控制—容灾主线与真题高度吻合。

二、综合知识高频考点（对应教材）

1. 加密技术（2026年真题直接考查）

- 对称加密（私钥加密）：加解密密钥相同，分分组密码与序列密码，代表算法IDEA、DES；**大批量数据加密首选AES**（DES已不安全）。
- 非对称加密（公钥加密）：RSA密钥512位，安全性基于大数分解难题，速度慢，主要用在数字签名中。RSA、ECC属于非对称加密，是经典辨析题。
- **3DES密钥长度**（案例考过）：使用两个56位密钥，总长度112位；抗抵赖通过**数字签名**实现。

2. 认证技术

- 加密确保保密性、阻止**被动攻击**（截取、窃听、业务流分析）；认证确保真实性与完整性、阻止**主动攻击**（冒充、篡改、重放）。案例真题考过“业务流分析属于被动攻击”。
- **重放攻击防范**：时间戳、序列号、一次性口令/挑战应答。
- 数字签名三点保证：鉴别（接收者可核实）、不可否认（发送者不可抵赖）、完整性（接收者不能伪造）。
- 杂凑算法：MD5输出128位摘要（512位分组处理）；SHA-1对不超过 2^{64} 位的消息产生160位摘要。
- 身份认证方式：口令认证（最不安全）、动态口令（一次一密）、生物特征识别。
- 数字证书：CA签发、X.509格式、CRL证书撤销列表。

3. 密钥管理体制

- KMI（封闭网，KDC静态/动态分发）、PKI（开放网，第三方管理，只提供数字签名服务；基础技术含数字信封）、SPK（LPK用RSA实现、CPK用DLP或ECC实现）三者对比是选择题常客。

4. 通信与网络安全

- SSL：传输层安全协议，由握手协议、记录协议、警报协议组成；HTTPS使用443端口。
- IPSec：针对IPv4和IPv6，基于端对端安全模式，假定传输媒介不安全。
- 防火墙三种体系结构：双宿/多宿主机、屏蔽主机、屏蔽子网（DMZ）；局限性包括不能防内部攻击、不能防不经过防火墙的攻击。
- VPN五项关键技术：隧道、加解密、密钥管理、身份认证、访问控制。
- 单点登录SSO与Kerberos（基于可信第三方、对称加密）。

5. 访问控制

- 三要素：主体、客体、控制策略。

- 模型辨析：**BLP**（保密性，上读下写）、**Biba**（完整性，下读上写，与BLP相反）、Lattice（多边安全）。
- 分类：DAC（UNIX普遍采用）、MAC（Multics，TCSEC B级）、**RBAC**（RBAC0~3四种模型，大型DBMS普遍应用）、TBAC（动态）、OBAC。
- 案例真题：RBAC中用户与角色是**多对多**关系；SQL注入漏洞可通过**预编译语句/参数化查询**修复。

6. 安全体系与等级保护

- 系统安全四分类：实体安全、运行安全（风险管理、审计跟踪、备份与恢复、应急）、信息安全、人员安全。
- 安全防范体系五层次：物理层、操作系统、网络、应用、安全管理。
- GB 17859—1999五个安全保护等级及各等级适用单位；注意等保已升级至2.0并新增数据安全专项标准（前述补充内容）。

三、案例与论文方向考点

- 1. 密码学案例（已考）**：CIA三大目标、3DES密钥长度、数字签名抗抵赖、重放攻击防范、被动/主动攻击判断。
- 2. 数据容灾案例（2026年考过）**：冷备、热备、双活的定义与区别；按**RPO/RTO要求**为不同业务（直播vs点播）选择容灾方案；从容灾演练、经济性、业务连续性角度论述实施注意事项。对应教材9.7节备份与恢复、灾难恢复内容。
- 3. 安全运维类**：容器安全（运行时应使用非root的指定UID用户）、Web安全等新场景开始出现在综合知识中。
- 4. 论文储备**：信息安全常与系统架构设计、微服务重构、数据治理结合命题，建议准备含加密体系、RBAC授权、容灾设计的项目素材。

四、备考优先级

- 1. 必拿分**：对称/非对称算法辨析（AES/RSA/ECC）、数字签名三点保证、BLP/Biba对比、串并联可靠性计算、被动vs主动攻击判断。
- 2. 重点突破**：PKI/KMI/SPK对比、防火墙三种模式、RBAC模型族、RPO/RTO与容灾等级。
- 3. 关注新趋势**：AI安全治理、零信任、等保2.0与数据安全新标准，可作为论文与案例的加分素材。